



File No.: EXP202208695

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On July 11, 2022, A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection.

The complaint is directed against the DIPUTACIÓN PROVINCIAL DE CUENCA with NIF P1600000B (hereinafter, the respondent).

The reasons on which the complaint is based are as follows:

The attendance control system in the respondent's Administration has been carried out in recent years through an authentication procedure with username/password on the Intranet.

Starting in June, the respondent installed various devices and markers with the purpose of establishing a new attendance control system based on fingerprint recognition.

The complainant states that they did not receive any information regarding the security procedures related to the processing of their biometric data.

Attached to the complaint is a document electronically submitted on 08/06/2022, with entry number 10475/2022, model "Generic Request from Employees of the Diputación de Cuenca," requesting information in this regard.

The complainant asserts that the processing of biometric data infringes upon the rights and freedoms of workers and that in the event of a security incident, the damage is irreversible, as an obsolete operating system is used.

They question why a system based on fingerprint recognition is being re-implemented if there are other less intrusive and proportional alternatives.

In particular, they request:

- 1.- Information on compliance with the GDPR.
- 2.- Information and/or a copy of the risk analysis conducted.
- 3.- Information and/or a copy of the DPIA, if it has been carried out.
- 4.- Information on the security measures implemented based on the risk analysis.
- 5.- In the event that the DPIA and/or the risk analysis conducted has determined a high risk, they request the deletion of biometric data from the system.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

They state that a month has passed without receiving a response.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on August 16, 2022, the complaint was forwarded to the respondent, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on August 16, 2022, as evidenced by the acknowledgment of receipt in the file.

On September 16, 2022, this Agency received a response from the DIPUTACIÓN PROVINCIAL DE CUENCA, indicating the following:

"The Provincial Council of Cuenca, on August 9, 2018, formalized an administrative services contract whose object was the 'service of support and maintenance of WCCRONOS (ATTENDANCE CONTROL),' with the awarded company, after the corresponding bidding procedure, being ABACO C.E. INFORMÁTICOS S.L.

Attached to this document is the contract formalized between the parties. Regarding the attendance

control system installed by this company in execution of the contract, the awarded company has stated and reiterated that 'THE IMAGE OF THE FINGERPRINT IS NEVER STORED AND CANNOT BE REPRODUCED.'

Specifically, we are informed that the operation of the system is as follows:

- A number generated by an algorithm based on the characteristics of the fingerprint (through the so-called minutiae, ridges, valleys, etc.) is stored/kept, and this number is associated with the worker's code (in our case, the public employee).
- THE FINGERPRINT IS NEVER STORED. In summary, it is specified that the fingerprint as such is neither stored nor can it be reproduced. A report issued by the Sole Administrator of ABACO C.E. INFORMÁTICOS S.L. is attached.

Furthermore, this company has sent to the Diputación a report prepared by the company that supplied the devices used for attendance control (SPEC S.A.), in which it is stated, among other considerations regarding identity protection, the following:

"Once the fingerprint has been scanned and the characteristic points (the minutiae) have been extracted, the scanned image is destroyed. Furthermore, it is completely impossible to obtain the original image of the fingerprint from the minutiae."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/23

The complaint was not forwarded to the Data Protection Officer until the moment the request from the Data Protection Agency, to which I am addressing, was received, to which the aforementioned complaint is attached.

Once this complaint was known, this Data Protection Officer proceeded to request from the various involved services (Human Resources and IT) all existing information regarding the implementation of the time control system and the possible implications regarding the processing of personal data, both to respond to the request from the Agency and to analyze the implications that such time control could have as a breach of data protection regulations.

The information provided to us by the involved Services is what we have presented in the first point of this document. On the other hand, this Provincial Council of Cuenca contracted with an external company (Govertis Advisory Services S.L.) for the development of a compliance and implementation plan for the General Data Protection Regulation of said provincial corporation, and as a result of this contract, the appropriate documentation was prepared:

Record of Processing Activities, a risk analysis was carried out, and the corresponding Data Protection Impact Assessment regarding the processing activities that were considered subject to the preparation of this assessment, etc.

The company that prepared this documentation considered that the time control implemented by the Provincial Council was not within the cases where the preparation of a DPIA was necessary.

Taking into account the above and in light of the information received, this Data Protection Officer has informed the data controller of the complaint and has decided to analyze whether the implemented time control system affects the right to data protection of the employees of this Provincial Council and, if so, to either replace this system with a less intrusive one or, based on a new risk analysis, to prepare the corresponding DPIA.

Likewise, public employees will be informed about the characteristics of the existing time control system, and a response will be provided to Mr. Romero regarding his request for information."

THIRD: On September 26, 2022, in accordance with Article 65 of the LOPDGGD, the complaint filed by the complainant was admitted for processing.

FOURTH: On February 10, 2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 35 of the GDPR and Article 13 of the GDPR, classified in Article 83.4 of the GDPR and Article 83.5 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/23

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the respondent submitted a written statement of allegations in which the following was stated:

“We reiterate what has already been reported in the previous written statement of allegations submitted on September 16, 2022, to said Agency.

In that document, which, as stated by the Agency itself, is part of this procedure, it is indicated:

‘The Provincial Council of Cuenca, on August 9, 2018, formalized an administrative services contract whose object was the “service of support and maintenance of WCCRONOS (PRESENCE CONTROL),” with the awarded company, after the corresponding bidding process, being ABACO C.E. INFORMÁTICOS S.L.

The contract formalized between the parties is attached to this document.

Regarding the presence control system installed by said company in execution of the contract, the awarded company stated and has reaffirmed that “THE IMAGE OF THE FINGERPRINT IS NEVER STORED AND CAN NEVER BE REPRODUCED.”

Specifically, we are informed that the operation of the system is as follows:

1 - A number is stored/generated by an algorithm based on the characteristics of the fingerprint (through the so-called minutiae, ridges, valleys, etc.), and this number is associated with the worker's code (in our case, the public employee).

- THE FINGERPRINT IS NEVER STORED. In summary, it is specified that the fingerprint as such is neither stored nor can it be reproduced.

A report issued by the Sole Administrator of ABACO C.E. INFORMÁTICOS S.L. is attached.

Furthermore, this company has sent to the Provincial Council a report prepared by the company that supplied the devices used for presence control (SPEC S.A.), in which it is stated, among other considerations regarding identity protection, the following:

“Once the fingerprint has been scanned and the characteristic points (the minutiae) have been extracted, the scanned image is destroyed. Furthermore, it is totally impossible to obtain the original image of the fingerprint from the minutiae.”

A report issued by the head of the R&D; department of SPEC S.A. is also attached.”

Based on these considerations, and as indicated in the accompanying reports, the digital fingerprint is not used in the access control system of the employees of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/23

Provincial Council of Cuenca, but rather an algorithm is used that, together with a key to be entered into the corresponding devices, proceeds to identify each of the employees at the time of entry and exit.

It is true that the algorithm is initially obtained based on the morphology of one part of the fingerprint, the minutiae, but starting from these, it is impossible to obtain the original fingerprint, since technically a fingerprint consists, in addition to these minutiae, of ridges or valleys, which have not been taken into account when extracting the identifying algorithm and, consequently, we reiterate that the fingerprint, which is the biometric data that would make a person identifiable to the exclusion of any other, cannot be extracted, as established by data protection regulations.

On the other hand, we consider it significant to highlight that the public employee is present at the moment when these minutiae of the fingerprint are extracted, and the destruction of the images is

immediate and carried out in their presence. Therefore, given these circumstances, it cannot be classified that this identification system involves the processing of personal data, much less the processing of special category data, since at the moment the corresponding public employee identifies themselves when accessing or leaving their workplace, the fingerprint is not used for their identification in any case.

The biometric systems used do not store the individual's fingerprint as is done in other types of records (for example, in police records).

Through complex mathematical algorithms, a numerical template is generated using information from certain points of the fingerprint.

In no case can the fingerprint be recovered from the information of these stored templates; furthermore, it is also not possible to deduce physical characteristics of the fingerprint from the template, as the extraction algorithm is only known by the manufacturer.

Well, as can be inferred from the technical reports contained in this Provincial Council, there is no stored fingerprint of any of its public employees, and consequently, there is no risk (neither significant nor non-significant) to the fundamental rights and freedoms of the same (all this aside from the legitimacy of Public Administrations, and even the legal obligation of time control of their employees). It is considered that the duty imposed in Article 13 of the GDPR is not infringed, as stated in the initiation agreement of this procedure to which these allegations are made.

In the same sense, and given this circumstance, the existence of a DPIA is not required of this Provincial Council, as established in the initiation agreement of the present sanctioning procedure, since the requirements established in the GDPR for the preparation of such an instrument are not met, as there is no risk in this identification process, nor is the establishment of additional mechanisms to guarantee the rights and freedoms of the affected individuals required.

Therefore, we understand that in this case, none of the two infringements attributed to this Provincial Council regarding the specific fact of monitoring the presence of its employees have been committed.”

SIXTH: On May 4, 2023, the instructor of the procedure agreed to carry out tests where the complaint filed by A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of preliminary investigative actions that are part of procedure AT/03590/2022 are reproduced for evidentiary purposes.

Likewise, the allegations to the initiation agreement of the referenced sanctioning procedure, submitted by the PROVINCIAL COUNCIL OF CUENCA, and the accompanying documentation are reproduced for evidentiary purposes.

SEVENTH: On May 12, 2023, a resolution proposal was made, notified electronically after prior notice in the initiation agreement that the subsequent procedures would be carried out through that means. In the resolution proposal, it is proposed:

That the Director of the Spanish Agency for Data Protection imposes on the PROVINCIAL COUNCIL OF CUENCA, with NIF P1600000B, a warning sanction for an infringement of Article 35 of the GDPR and Article 13 of the GDPR, classified under Article 83.4 of the GDPR and Article 83.5 of the GDPR.

That the Director of the Spanish Agency for Data Protection orders the PROVINCIAL COUNCIL OF CUENCA, with NIF P1600000B, to comply with Article 58.2.d) of the GDPR, within one month, to provide evidence of having offered information to users whose personal data is collected in order to comply with the requirements set forth in Article 13 of the GDPR, as well as the provision of evidentiary means of compliance with the requirements.

No allegations have been received from the accused party regarding this resolution proposal.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: The Provincial Council of Cuenca installed a new attendance control system based on fingerprint recognition, without providing workers with information regarding the security procedures related to the processing of their biometric data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

7/23

SECOND: The responding party considers that the time control implemented by the provincial council was not within the circumstances that required the preparation of an impact assessment regarding data protection. Thus, it is confirmed that such an assessment has not been prepared.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Article 4 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data and the free movement of such data (General Data Protection Regulation, hereinafter GDPR), under the heading "Definitions," provides that:

"For the purposes of this Regulation, the following definitions shall apply:

- 1) 'personal data': any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;
- 2) 'processing': any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction;"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/23

III

From the facts subject to this complaint, a possible lack of information to the workers of the public body in question arises despite the request made by them.

In this regard, it should be noted that Article 13 of the GDPR provides that:

"1. When personal data are obtained from a data subject, the controller shall provide the data subject with all the following information at the time of obtaining the data:

- a) the identity and contact details of the controller and, where applicable, of the controller's representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;
- d) where the processing is based on Article 6(1)(f), the legitimate interests pursued by the controller or by a third party;
- e) the recipients or categories of recipients of the personal data, if any;
- f) where applicable, the intention of the controller to transfer personal data to a third country or an

international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49(1), second paragraph, reference to the appropriate or suitable safeguards and the means by which to obtain a copy of them or the fact that they have been provided.

2. In addition to the information mentioned in paragraph 1, the controller shall provide the data subject, at the time of obtaining the personal data, with the following information necessary to ensure fair and transparent processing:

- a) the period for which the personal data will be stored or, if that is not possible, the criteria used to determine that period;
- b) the existence of the right to request from the controller access to personal data relating to the data subject, and their rectification or erasure, or restriction of processing;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/23

of their treatment, or to oppose the treatment, as well as the right to data portability;

- c) when the treatment is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the treatment based on consent prior to its withdrawal;

- d) the right to lodge a complaint with a supervisory authority;

- e) whether the communication of personal data is a legal or contractual requirement, or a necessary requirement to enter into a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of not providing such data;

- f) the existence of automated decisions, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, significant information about the logic involved, as well as the significance and the expected consequences of such treatment for the data subject.

3. When the data controller intends to further process personal data for a purpose other than that for which it was collected, it shall provide the data subject, prior to such further processing, information about that other purpose and any additional relevant information pursuant to paragraph 2.

4. The provisions of paragraphs 1, 2, and 3 shall not apply when and to the extent that the data subject already has the information.”

For its part, Article 11 of the LOPDGDD provides as follows:

“1. When personal data is obtained from the affected party, the data controller may fulfill the information duty established in Article 13 of Regulation (EU) 2016/679 by providing the affected party with the basic information referred to in the following paragraph and indicating an electronic address or other means that allows easy and immediate access to the remaining information.

2. The basic information referred to in the previous paragraph must contain, at least:

- a) The identity of the data controller and its representative, if applicable.
- b) The purpose of the processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/23

c) The possibility of exercising the rights established in Articles 15 to 22 of Regulation (EU) 2016/679. If the data obtained from the affected party is to be processed for profiling purposes, the basic information will also include this circumstance. In this case, the affected party must be informed of their right to object to the adoption of automated individual decisions that produce legal effects concerning them or similarly significantly affect them, when this right applies in accordance with the provisions of Article 22 of Regulation (EU) 2016/679.”

Therefore, we must consider that there has been a violation of Article 13 of the GDPR by not providing

workers with general information about the implementation of the new fingerprint-based time tracking system, despite their request on 08/06/2022, which would imply a violation of the right to information recognized in Article 13 of the GDPR, as indicated in this legal basis.

IV

By virtue of the provisions of Article 58.2 of the GDPR, the Spanish Data Protection Agency, as the supervisory authority, has a set of corrective powers in the event of a violation of the provisions of the GDPR.

Article 58.2 of the GDPR provides as follows:

"2 Each supervisory authority shall have all of the following corrective powers indicated below:

(...)

b) to issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation;"

(...)

"d) to order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time frame;"

Article 83.5.b) of the GDPR establishes that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/23

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the rights of the data subjects pursuant to Articles 12 to 22;"

In turn, Article 72.1 h) of the LOPDGDD, under the heading "Very Serious Violations," states:

"1. In accordance with Article 83.5 of Regulation (EU) 2016/679, the following violations are considered very serious and shall be subject to a three-year limitation period, which involve a substantial breach of the articles mentioned therein, and in particular, the following:

h) The failure to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and Article 12 of this organic law."

V

Regarding the use of fingerprint data, which is also the subject of this complaint, we must indicate that biometric data is defined in Article 4.14 of the GDPR as follows:

"'biometric data': personal data obtained from a specific technical processing related to the physical, physiological, or behavioral characteristics of a natural person that allow or confirm the unique identification of that person, such as facial images or fingerprint data;"

The scope of application of the GDPR extends its protection, as established in Article 1.2, to the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data, defined in Article 4.1 as "any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person."

Each individual has unique fingerprints that exhibit specific characteristics that can be measured to determine whether a fingerprint matches a registered sample. Biometric data has the particularity of being produced by the body itself and characterizes it definitively.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

Therefore, they are unique, permanent over time, and the person cannot rid themselves of them; they can never be changed, not even with age, creating issues of liability in the event of compromise, loss, or intrusion into the system.

They are data whose use may pose significant risks to fundamental rights and freedoms, and therefore their use is initially prohibited in accordance with Article 9.1 of the GDPR, which is further indicated in Article 9.4 of the GDPR that:

"Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or data concerning health."

VI

The GDPR makes the application of all compliance measures it provides for controllers and processors dependent on the level and type of risk that each processing operation entails for the rights and freedoms of the affected individuals.

Article 28 of the LOPDGD states the following obligations:

1. Controllers and processors, taking into account the elements listed in Articles 24 and 25 of Regulation (EU) 2016/679, shall determine the appropriate technical and organizational measures that must be applied to ensure and demonstrate that the processing is in compliance with the aforementioned regulation, this organic law, its implementing rules, and the applicable sectoral legislation. In particular, they will assess whether a data protection impact assessment and prior consultation as referred to in Section 3 of Chapter IV of the aforementioned regulation is necessary. Article 32 of the GDPR also states as one of the factors to consider, "the varying probability and severity of risks to the rights and freedoms of natural persons" for the application of appropriate measures to ensure "a level of security appropriate to the risk."

The paradigm shift from the previous regulation brought about by the GDPR is evidenced by the requirement that security measures must be tailored to the characteristics of the processing, its risks, and the context in which it occurs, as well as the state of the art and costs. This contrasts with the previous LOPD, which based security measures primarily on the type of data being processed. The application of measures now cannot be automatically derived from whether certain data is being processed; rather, it must be the result of a specific risk analysis for each processing operation. The management of risks related to data processing operations subject to the GDPR implies that all decisions related to such processing, and not only those linked to its security, must be based on risk management. There is always an inherent risk in processing, simply by virtue of carrying it out; therefore, the goal of the risk management process is to keep it at acceptable levels. Managing risks involves assessing and addressing them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

In the context of Public Administrations (AAPP), in addition to risk analysis methodologies focused on information security, these must be expanded to include risks associated with non-compliance with the provisions of the GDPR.

Public Administrations, as they are responsible for processing the data of citizens or their employees, must identify the risks to which the processing may be exposed before launching new processing activities or modifying existing services that make use of new technologies.

Therefore, all processing, both existing and intended to be initiated, must be subject to a risk analysis. Risks are not static; they evolve continuously, so once identified, they require an effort of continuous and permanent supervision. The correct attitude is to know the risk, assess its consequences, take measures to minimize it, and control its effectiveness in a changing context.

This scheme of continuous supervision is what is defined as risk management.

The assessment, management, and minimization of risk to rights and freedoms is an obligation of the

data controller (Articles 23.2.g, 24.1, 25, 32, 33, 34, 35, and 36 among others) and is part of the compliance checklist.

The GDPR, although it provides some indications, is not specific when it comes to identifying and outlining how to manage the risk of each processing activity specifically.

The respondent provides a copy of the "security measures that ensure that personal data presents the minimum security risks, according to the risk analysis conducted," which accompanies as ANNEX IV, carried out on 01/16/2021, with the GESTIONA tool from the AEPD. Regarding this assessment, it should be specified:

- It is a compliance assistance tool intended to support decision-making, and its use generates basic documentation that is in no case exhaustive, upon which a risk analysis and management must be carried out by those responsible for complying with the provisions of the GDPR and LOPDGDD.

This basic documentation will be a starting point that must be completed by following the guidelines of the risk management and impact assessment guide in personal data processing.

- It is a tool aimed at SMEs, not Public Administrations, which are different subjects that have different risk profiles in processing compared to another controller, with the characteristic that it can impose processing on a broad collective, with the impossibility in many cases of opposing it, affecting rights and freedoms, such as could be, among others, with the proportional reduction of wages as unworked or unjustified service time through the fingerprint time recording system implemented before the entry into force of the GDPR, with the LOPD.

The "Guide for an Impact Assessment on Personal Data Protection" published in June 2022 by the AEPD indicated that there are multiple methodologies for risk analysis that may be suitable for the intended objective, without including specific guidelines in that area. However, due to its relevance and adaptation to the specific case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/23

In the specific context of privacy, reference was made to the publication "Methodology for Privacy Risk Management" by the Commission Nationale de l'Informatique et des Libertés (CNIL), to MAGERIT (Methodology for Analysis and Management of Information Systems Risks), a tool created by the Superior Council of Electronic Administration to assist various public bodies in this area, to Risk IT (ISACA) or ISO 27005, and also highlighting for these purposes the usefulness of ISO 31000 standards on principles and guidelines for risk management and the ISO 31010 standard on risk management techniques, which detail various methods that can help identify and detect the risks of a new product or service.

- What the defendant provides regarding the security measures of the processing related to the risks does not take into account the fact that the risks to be assessed in relation to security are only one of the aspects to be covered, ignoring the management of risks to the rights and freedoms in the context of personal data processing, as well as the effectiveness and efficiency of the legal and technical safeguards applied.

VII

It is deduced from the analysis carried out thus far that special category personal data is being processed.

The GDPR imposes the obligation to have a Data Protection Impact Assessment (hereinafter DPIA), as determined by Article 35 of the GDPR:

"1. When a type of processing is likely to result in a high risk to the rights and freedoms of natural persons, in particular if it uses new technologies, by its nature, scope, context, or purposes, the controller shall carry out, prior to the processing, an assessment of the impact of the processing operations on the protection of personal data. A single assessment may address a set of similar processing operations that present similar high risks.

2. The controller shall seek the advice of the data protection officer, if designated, when carrying out the data protection impact assessment.

3. The data protection impact assessment referred to in paragraph 1 shall be required in particular in the case of:

- a) systematic and comprehensive evaluation of personal aspects of natural persons based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural persons or similarly significantly affect them;
- b) large-scale processing of special categories of data referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses referred to in Article 10, or
- c) systematic large-scale monitoring of a publicly accessible area.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/23

4. The supervisory authority shall establish and publish a list of the types of processing operations that require a data protection impact assessment in accordance with paragraph 1. The supervisory authority shall communicate these lists to the Committee referred to in Article 68.

5. The supervisory authority may also establish and publish a list of the types of processing that do not require data protection impact assessments. The supervisory authority shall communicate these lists to the Committee.

6. Before adopting the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism provided for in Article 63 if those lists include processing activities related to the offering of goods or services to data subjects or the monitoring of their behavior in several Member States, or processing activities that may substantially affect the free movement of personal data within the Union.

7. The assessment shall include at least:

- a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where appropriate, the legitimate interest pursued by the data controller;
- b) an assessment of the necessity and proportionality of the processing operations in relation to their purpose;
- c) an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1; and
- d) the measures envisaged to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of data subjects and other affected persons.

8. Compliance with the approved codes of conduct referred to in Article 40 by the respective controllers or processors shall be duly taken into account when assessing the impact of the processing operations carried out by such controllers or processors, particularly for the purposes of the data protection impact assessment.

9. Where appropriate, the controller shall seek the opinion of data subjects or their representatives regarding the envisaged processing, without prejudice to the protection of public or commercial interests or the security of processing operations.

10. When the processing based on Article 6, paragraph 1, letters c) or e), has its legal basis in Union law or in the law of the Member State applicable to the data controller, such law regulates the specific processing operation or set of operations in question, and a data protection impact assessment has already been carried out as part of a general impact assessment in the context of the adoption of such legal basis, paragraphs 1 to 7 shall not apply unless Member States deem it necessary to proceed with such assessment prior to the processing activities.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/23

11. If necessary, the controller will examine whether the processing is in accordance with the data protection impact assessment, at least when there is a change in the risk posed by the processing operations.”

In furtherance of paragraph 4, the Director of the AEPD published a non-exhaustive indicative list of types of processing that require a data protection impact assessment, stating: “When analyzing data processing, it will be necessary to carry out a DPIA in most cases where such processing meets two or more criteria from the list set out below, unless the processing is included in the list of processing operations that do not require a DPIA referred to in Article 35.5 of the GDPR.”

The list is based on the criteria established by the “GUIDELINES ON DATA PROTECTION IMPACT ASSESSMENT (DPIA) AND FOR DETERMINING IF PROCESSING ‘LIKELY TO RESULT IN HIGH RISK’ UNDER THE GDPR,” adopted on 4/04/2017 and last revised and adopted on 4/10/2017, WP 248 rev.01 of the Article 29 Working Party, which complements it and should be understood as a non-exhaustive list:

“4. Processing that involves the use of special categories of data referred to in Article 9.1 of the GDPR, data related to criminal convictions or offenses referred to in Article 10 of the GDPR, or data that allow for the determination of financial status or solvency or the deduction of information about individuals related to special categories of data.

5. Processing that involves the use of biometric data for the purpose of uniquely identifying a natural person.”

9. Processing of data of vulnerable subjects...”

In the same Guidelines, it is noted:

“In order to provide a more concrete set of processing operations that require a DPIA due to their inherent high risk, taking into account the specific elements of Article 35, paragraph 1, and Article 35, paragraph 3, letters a) to c), the list to be adopted at the national level under Article 35, paragraph 4, and recitals 71, 75, and 91, and other references in the GDPR to processing operations that ‘likely entail high risk’, the following nine criteria should be considered:

“7. Data relating to vulnerable data subjects (recital 75):

The processing of this type of data represents a criterion due to the increased power imbalance between the data subjects and the data controller, which implies that individuals may be unable to authorize or deny the processing of their data, or to exercise their rights.

Vulnerable data subjects may include children (who are considered incapable of consciously and responsibly authorizing or denying the processing of their data), employees.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/23

Regarding the registration system and use of fingerprints, which are novel and highly intrusive identification systems for the fundamental rights and freedoms of individuals, the GDPR establishes the obligation to manage the risk that such processing poses to the rights and freedoms of individuals. This risk arises both from the very existence of the processing and from its technical and organizational dimensions.

The risk arises from the purposes of the processing and its nature, as well as from its scope and the context in which it operates.

The complexity of the risk management process must be adjusted not to the size of the entity, the availability of resources, the specialty or sector of the entity, but to the possible impact of the processing activity on the data subjects and to the inherent difficulty of the processing.

Biometric processing presents among others the following risks, some of which are contemplated in OPINION 3/2012 ON THE EVOLUTION OF BIOMETRIC TECHNOLOGIES of the Article 29 Working Party dated 27/04/2012:

- The definition of the size (amount of information) of the biometric template is a crucial issue.

On one hand, the size of the template must be large enough to manage security (avoiding overlaps

between different biometric data or identity substitutions), and on the other hand, it should not be too large in order to avoid the risks of reconstructing biometric data.

- Risks associated with the use of biometric data for identification purposes in large centralized databases, given the potentially harmful consequences for the affected individuals.
- It goes without saying that any loss of the qualities of integrity, confidentiality, and availability concerning the databases would be clearly detrimental to any future application based on the information contained in such databases and would also cause irreparable harm to the data subjects. For example, if the fingerprints of an authorized person were associated with the identity of an unauthorized person, the latter could access the services available to the owner of the fingerprints without having the right to do so.

The result would be identity theft, which (regardless of its detection) would undermine the reliability of the fingerprints of the person for future applications and, consequently, limit their freedom.

- The transfer of the information contained in the database.
- It may create the illusion that identification through the fingerprint is always correct; therefore, an analysis of the errors that may occur in its use, performance evaluation metrics, false acceptance rate—probability that a biometric system incorrectly identifies an individual or

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/23

do not reject an individual who does not belong to the group, and false rejection or false negative rate: correspondence between a person and their own template is not established.

In the face of decisions that legally affect a person, any decision made based on this should only be carried out while safeguarding the rights and freedoms and the legitimate interests of the affected party, at a minimum the right to obtain human intervention by the controller, to express their point of view, and to contest the decision.

- Security measures must be adopted regarding the processing of biometric data (storage, transmission, feature extraction, and comparison, etc.) and especially if the data controller transmits that data over the Internet.

Security measures could include, for example, the encryption of templates and the protection of encryption keys apart from access control and protection that makes it virtually impossible to reconstruct the original data from the templates.

- Likewise, the WORKING DOCUMENT ON BIOMETRICS, adopted on 1/08/2003, by the GT29, opines that biometric systems related to physical characteristics that leave no trace (for example, the shape of the hand, but not fingerprints) or biometric systems related to physical characteristics that leave a trace but do not depend on the memorization of data held by a person other than the data subject (in other words, the data is not memorized in the access control device or in a central database) pose less risk to the protection of the fundamental rights and freedoms of individuals (Biometric data that is processed in a centralized manner can be distinguished from biometric reference data that is stored on a mobile device and the conformity process is carried out on the card and not on the sensor or when it is part of the mobile device).

- It is generally accepted that the risk of reusing biometric data obtained from physical traces left by individuals unknowingly (for example: fingerprints) for incompatible purposes is relatively low if the data is not stored in centralized databases, but is in the possession of the individual and is inaccessible to third parties.

The centralized storage of biometric data also increases the risk of using biometric data as a key to interconnect different databases, which could allow for the creation of detailed profiles of a person's habits at both public and private levels.

Furthermore, the issue of the compatibility of purposes leads us to the interoperability of different systems that use biometrics.

The standardization required for interoperability may result in greater interconnection between databases.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/23

- Obvious risks if the technology used does not sufficiently guarantee that the template obtained from biometric data will not match that used in other similar systems.

Regarding the guarantees to be implemented that must be included in the DPIA, the Guide "Data Protection in Employment Relationships" by the AEPD considers, for reference, ten aspects that can be taken into account.

The respondent has stated that the DPIA was not carried out because once the fingerprint has been scanned and the characteristic points (minutiae) have been extracted, the scanned image is destroyed.

Furthermore, the Provincial Council of Cuenca states that it believes that the time control implemented does not fall within the cases where a DPIA is necessary.

In this regard, it should be noted that the Guidelines of Working Group 29 on the impact assessment related to data protection and to determine whether the processing "likely entails a high risk" for the purposes of Regulation (EU) 2016/679 adopted on 04/04/2017, last revised and adopted on 04/10/2017, indicate regarding existing processing operations that "The requirement to carry out a DPIA applies to existing processing operations that likely entail a high risk to the rights and freedoms of natural persons and for which there has been a change in risks, taking into account the nature, scope, context, and purposes of the processing."

In addition to the aforementioned legal basis that highlights that an insufficient and inadequate basic risk assessment for the rights and freedoms of the affected individuals has been executed, it should be added that a DPIA should also be perceived as a decision-making aid tool regarding processing, so it is advisable to carry it out in the conception and design phases of the processing.

This would comply with the principles of data protection by design and help ensure that the selected guarantees are guided by risk management and implemented during the conception and design phase of the processing, being integrated into it and extending to all stages of its lifecycle.

Data protection by design is not an additional layer or an element that can be added afterwards.

Therefore, a DPIA may imply that changes need to be made to the processing to introduce modifications, guarantees, or measures to reduce risks; it must be carried out before and during the design phase, and the risk-based approach that a DPIA entails is a process, not a state.

The respondent did not consider the various and diverse elements that have been pointed out in this section in its risk assessment and has stated that there is no risk or that it is acceptable; these elements must at least be part of the aforementioned impact assessment.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

20/23

The DPIA is a necessary step for data processing, not being the only requirement; it is a prerequisite to which the rest of the legal requirements for processing must be added, forming the legitimizing basis and respecting the fundamental principles of data processing provided for in Article 5 of the GDPR.

The respondent has not demonstrated compliance with this obligation, and it is therefore estimated that it may have incurred in the aforementioned infringement of Article 35 of the GDPR.

VIII

The infringement attributed is classified under Article 83.4.a) of the GDPR, which states:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) The obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

The LOPDGDD establishes in its Article 73.t):

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall prescribe after two years: violations that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

t) The processing of personal data without having carried out the impact assessment of the processing operations on personal data in cases where it is required.”

IX

By virtue of what is established in Article 58.2 of the GDPR, the Spanish Data Protection Agency, as the supervisory authority, has a set of corrective powers in the event of an infringement of the provisions of the GDPR.

Article 58.2 of the GDPR provides as follows:

“2 Each supervisory authority shall have all of the following corrective powers:

(...)

b) issue a warning to any controller or processor when the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/23

operations of processing have infringed the provisions of this Regulation;”

(...)

“d) order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified timeframe;”

(...)

“i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this section, depending on the circumstances of each particular case;”

Considering that the respondent is a public entity that is part of the Autonomous Community of Castilla La Mancha, Article 83.7 of the GDPR states:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

The “Applicable Regime for Certain Categories of Controllers or Processors” of the LOPDGDD provides in its Article 77 in the wording in force at the time the events occurred:

[...]

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed. The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, if applicable, and to the affected parties who had the status of interested parties, if applicable.

(...)

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

In its paragraph 1 it states

“1. The regime established in this article shall apply to the processing for which they are responsible or processors:

[...]”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/23

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.”

Therefore, in light of the above, this Agency considers that we are facing a double infringement, the first in accordance with Article 13 of the GDPR and the second according to Article 35 of the GDPR, indicated in the legal grounds III and VII respectively, as a consequence of these two facts:

1.

The lack of information to the workers regarding the attendance control system that involves the processing of biometric data of said workers of the respondent party and

2.

The acknowledged lack of Data Protection Impact Assessment by the PROVINCIAL COUNCIL OF CUENCA.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: DECLARE that the PROVINCIAL COUNCIL OF CUENCA, with NIF P1600000B, has infringed the provisions of Article 35 of the GDPR and Article 13 of the GDPR, infringements classified in Article 83.4 of the GDPR and Article 83.5 of the GDPR respectively.

SECOND: NOTIFY this resolution to the PROVINCIAL COUNCIL OF CUENCA.

THIRD: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

FOURTH: Require under the application of Articles 90.3 of the LPCAP, and 58.2.f), of the GDPR, the PROVINCIAL COUNCIL OF CUENCA, with NIF P1600000B, to “temporarily or definitively limit the processing” of the time control system through fingerprinting, as long as it does not have a valid data protection impact assessment of the processing, which takes into account the risks to the rights and freedoms of employees and the appropriate measures and guarantees for its processing, or even if it is carried out, it must make the consultation provision established in Article 36 of the GDPR and inform the workers of the implementation of the new time control system, based on fingerprinting, providing the information required under Article 13 of the GDPR.

After the granted time has elapsed, it must inform this AEPD.

Failure to comply with the requirement may result in the commission of an infringement of Article 83.6 of the GDPR,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/23

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in

Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es